

Daily Vulnerability Report - 2026-09-12

Window (UTC): 2026-09-12T00:00 to 2026-09-13T00:00 | Sources: NVD, CISA KEV, EPSS, Vulnrichment, GHSA, OSV | Generated 2026-09-17 11:39:13 UTC

Total	New	Updated	KEV added	KEV	Critical	High	Medium	Unscored	Watchlist
104	99	1	4	6	14	27	48	11	4

New today - published in this report window

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85706	New	10.0	CRIT	Yes	0.12	gitlab:gitlab	GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.7 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that, under certain conditions, an unauthenticated user could have read arbitrary files from the GitLab server due to improper path confinement and missing authentication enforcement in the repository commits API.
CVE-2026-82845	New	9.9	CRIT		0.004		The Masteriyo LMS WordPress plugin before 3.4.1 does not prevent user-supplied values held as metadata from being deserialized when they are read back, allowing users with a minimal account to inject arbitrary PHP objects and, by way of a class shipped in a library bundled with the Masteriyo LMS WordPress plugin before 3.4.1, write and execute arbitrary code on the server....
CVE-2026-87719	New	9.9	CRIT		0.006		GitLab has remediated an issue in GitLab EE affecting all versions from 18.3 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could allow an authenticated user with Duo Chat access to obtain Advanced Search instance configurations and sensitive credentials using a specially crafted GraphQL subscription argument to bypass serialization a...
CVE-2026-75800	New	9.8	CRIT		0.004		The Frontegg SAML SSO WordPress plugin through 1.0.1 does not verify the signature or issuer of SAML authentication responses before establishing a session, allowing unauthenticated attackers to log in as any user, including administrators, as well as to create arbitrary accounts.
CVE-2026-78006	New	9.8	CRIT		0.008		The The Events Calendar plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 6.17.4 via the is_safe_widget_instance function. This is due to insufficient protection in is_safe_widget_instance, which can be bypassed because PHP fires magic methods during its pre-parse, combined with enable_rendering_widget_copied() forging a valid ...
CVE-2026-78159	New	9.8	CRIT		0.008		The The Events Calendar plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 6.17.3 via the parse_array function. This is due to insufficient validation of the widget 'classes' map, allowing a plain-array payload to bypass the is_safe_widget_instance() object check and reach the callable-invocation sink in Element_Classes::parse_a...
CVE-2026-81402	New	9.8	CRIT		0.004		The DS Ad Rotator WordPress plugin through 0.8 does not perform any capability check, nonce verification, or file-type validation on its image upload handler, allowing unauthenticated attackers to upload arbitrary files, including PHP, to a web-accessible directory, which can lead to remote code execution.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84171	New	9.8	CRIT		0.004		The WP images upload on piclect WordPress plugin through 1.0 does not validate the name or type of uploaded files before writing them to a publicly accessible directory, allowing unauthenticated attackers to upload arbitrary files and execute arbitrary code on the server.
CVE-2026-85681	New	9.8	CRIT		0.003		The WP Component WordPress plugin through 2.2.4 does not have any capability or nonce checks on one of the actions it makes available to unauthenticated users, and it takes both the option name and the option value from the request, allowing unauthenticated attackers to overwrite any of the site's options. On a single site installation this leads to a full takeover, as regis...
CVE-2026-77005	New	9.6	CRIT		0.003		The CODE MONKEYS PROPOSALS WordPress plugin through 1.0.1 does not validate a user-supplied file path before deleting a file, and does not check the capability of the user making the request, allowing any authenticated user, such as a subscriber, to delete arbitrary files on the server, which can lead to a site takeover.
CVE-2026-77006	New	9.6	CRIT		0.002		The WebTotem Backups WordPress plugin through 1.0.1 does not validate a user-supplied file path, does not check the capability of the user making the request, and discards the result of its own CSRF check, allowing any authenticated user, such as a subscriber, to delete arbitrary files on the server, which can lead to a site takeover.
CVE-2026-90558	New	9.3	CRIT		0.005		sngrep through 1.8.4 contains stack buffer overflow vulnerabilities in SIP attribute formatting routines when header values exceed the 255-byte buffer limit. Attackers can craft malicious SIP packets with oversized Call-ID, X-Call-ID, or other header fields to overflow stack buffers and cause crashes or execute arbitrary code during packet parsing and rendering.
CVE-2026-90647	New	9.1	CRIT		0.001		ASE/Kalkitech ASE2000 V2 Communication Test Set 2.35 through 2.37 on Windows contains an improper certificate validation vulnerability in the IEC 60870-5-104 TLS client (Task Mode). This allows a network-positioned attacker to bypass certificate validation via a certificate with multiple simultaneous faults, enabling a Man-in-the-Middle attack on protected communications.
CVE-2026-15451	New	8.8	HIGH		0.002		The MemberPress Corporate Accounts plugin for WordPress is vulnerable to Privilege Escalation in versions up to, and including, 1.5.39. This is due to a mass assignment vulnerability in the 'add_sub_account_user' function that passes the raw 'userdata' array to 'wp_insert_user' without filtering dangerous keys like role or ID. This makes it possible for authenticated attacke...
CVE-2026-78175	New	8.8	HIGH		0.006		The Tutor LMS – eLearning and online course solution plugin for WordPress is vulnerable to PHP Object Injection in all versions up to, and including, 4.0.7 via the `withdraw_method_field` parameter of the `tutor_save_withdraw_account` AJAX handler. This is due to the handler lacking any capability or role check, relying solely on a nonce, while also passing attacker-supplied...
CVE-2026-81742	New	8.8	HIGH		0.003		The BE REST Endpoints WordPress plugin through 1.0.0 does not perform any authorization check before allowing widgets to be read, created, updated and deleted, and does not sanitize the values it stores in them, allowing unauthenticated users to inject arbitrary web scripts which will execute in the browser of any user visiting the site.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87759	New	8.8	HIGH		0.002		The Add User Autocomplete WordPress plugin before 1.2 does not perform any capability or nonce check before creating a pending site-membership invitation carrying a caller-supplied role, allowing any authenticated user, such as a subscriber, to grant themselves the administrator role on a multisite installation.
CVE-2026-90537	New	8.8	HIGH		0.002		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a missing authorization vulnerability in plugin/Scheduler/sendEmail.json.php that allows unauthenticated attackers to access scheduler email jobs by providing a site-wide daily token. Attackers can enumerate scheduler jobs, read private live titles and email addresses, and trigger email sending by s...
CVE-2026-90560	New	8.8	HIGH		0.003		zstd-jni versions 1.2.0 through 1.5.7-13 contain an out-of-bounds read vulnerability in the ZstdDictDecompress constructor because offset and length arguments are never validated against the dictionary array bounds. Attackers can supply arbitrary offset or length values to read memory past the end of the supplied array, potentially causing JVM termination.
CVE-2026-90559	New	8.7	HIGH		0.004		snappy-java through 1.1.10.8 contains an out-of-bounds write vulnerability in Snappy.uncompress(ByteBuffer, ByteBuffer) because destination buffer capacity is never validated against decompressed size. Attackers can supply valid compressed data that decompresses larger than the destination buffer, causing writes past buffer boundaries and JVM termination.
CVE-2026-80491	New	8.6	HIGH		0.003		The SAMO Forms WordPress plugin through 1.0.0 does not properly sanitise and escape user input before using it in SQL queries in several unauthenticated actions, allowing unauthenticated attackers to perform SQL injection attacks.
CVE-2026-80494	New	8.6	HIGH		0.003		The Yogeta WP Cloud WordPress plugin through 1.0 does not validate a user-supplied file path before passing it to a file-read function on a public endpoint that lacks any authorization check, allowing unauthenticated attackers to download arbitrary files from the server, including files containing sensitive credentials.
CVE-2026-84047	New	8.6	HIGH		0.003		The Album Cover Finder WordPress plugin through 0.7.0 does not properly sanitize and escape a parameter before using it in a SQL query, allowing unauthenticated users to perform SQL injection attacks.
CVE-2026-90553	New	8.5	HIGH		0.002	vllm:vllm	vLLM before 0.28.0 contains a remote code execution vulnerability in the LlavaOnevision2 processor loader that ignores the trust_remote_code parameter when loading remote processor classes. Attackers can craft a malicious model with arbitrary code in processing_llava_onevision2.py that executes with vLLM process authority even when trust_remote_code is set to False.
CVE-2026-89266	New	8.2	HIGH		0.005		stb_vorbis through 1.22 contains a heap buffer overflow in start_decoder() where the codebook multiplicands allocation size is truncated from size_t to int. Attackers can craft a malicious Ogg Vorbis file with large entries and dimensions values to trigger out-of-bounds writes, causing process crashes or heap corruption.
CVE-2026-84099	New	8.1	HIGH		0.003		The wpstorecart WordPress plugin through 5.0.7 does not prevent direct, unauthenticated access to a bundled add-on that deserializes user-supplied input without restricting the permitted classes, allowing unauthenticated attackers to inject arbitrary PHP objects, which may be escalated further when a suitable gadget chain is present on the site.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-87888	New	8.0	HIGH		0.002		The YayPricing WordPress plugin before 3.5.7 does not perform an authorization check on a REST route that saves its pricing rules, allowing users with the subscriber role and above to store JavaScript that executes in the browser of an administrator who opens the YayPricing WordPress plugin before 3.5.7's settings page.
CVE-2026-90556	New	7.8	HIGH		0.001		Freeciv versions before 3.2.6 contain a heap buffer overflow in worklist_load() when processing savegame files with declared worklist lengths exceeding the fixed array bound of 64 elements. Attackers can craft malicious savegame files that write past the entries array into adjacent heap-allocated struct fields, potentially corrupting memory when a user or server operator loa...
CVE-2026-90474	New	7.6	HIGH		0.003		MCPhub before 1.0.32 contains an authentication bypass vulnerability in its embedded OAuth 2.0 authorization server where client authentication is disabled by default and PKCE enforcement is optional. Attackers who obtain an authorization code through interception can redeem it for access tokens without providing a client secret or PKCE verifier, gaining access to victim acc...
CVE-2026-16482	New	7.5	HIGH		0.003		The rtMedia for WordPress, BuddyPress and bbPress plugin for WordPress is vulnerable to time-based blind SQL Injection via the 'compare' parameter in all versions up to, and including, 4.7.11 due to insufficient escaping on the user supplied parameter and lack of sufficient preparation on the existing SQL query. This makes it possible for unauthenticated attackers to append ...
CVE-2026-85200	New	7.5	HIGH		0.019		The GEO my WP plugin for WordPress is vulnerable to Local File Inclusion in all versions up to, and including, 4.5.5.3 via the gmw_posts_locator_ajax_info_window_loader function. This makes it possible for unauthenticated attackers to include and execute arbitrary .php files on the server, allowing the execution of any PHP code in those files. This can be used to bypass acce...
CVE-2026-87842	New	7.5	HIGH		0.003		The Zonify WordPress plugin before 1.0.5 does not perform any capability or authentication check before returning the site's stored account login token, allowing unauthenticated attackers to retrieve it and authenticate to the site owner's linked service account.
CVE-2026-90535	New	7.5	HIGH		0.003	flowiseai:flowise	Flowise versions before 3.1.4 contain an unauthenticated denial of service vulnerability in the /api/v1/text-to-speech/abort endpoint that accepts user-supplied chatflowId and chatId without ownership verification. Attackers can terminate active chatflow predictions for any user by submitting requests with known chatflow and chat identifiers, causing targeted service disrupt...
CVE-2026-90616	New	7.4	HIGH		0.002		In Flatpak before 1.18.1, a malicious sandboxed app can obtain arbitrary read and write access to files on the host, which can be escalated to arbitrary code execution on the host, a different vulnerability than CVE-2026-76925. Flatpak creates a few app data directories (e.g., /var/cache, /var/data, /var/config, and /var/tmp) in every sandbox on every app launch where, in so...
CVE-2026-77705	New	7.2	HIGH		0.003		The Booking for Appointments and Events Calendar WordPress plugin before 2.4.10 does not verify that the user editing a customer or employee record is entitled to modify the WordPress account linked to it, allowing users holding Amelia's customer or employee management permissions to set the password and email address of other users' WordPress accounts and take them over.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77752	New	7.2	HIGH		0.003		The Temporary Login Without Password WordPress plugin before 1.9.9 does not verify that the user requesting a temporary login holds network super admin rights before granting the new account those rights, allowing an administrator of a single site on a multisite network to take over the whole network. The same missing check also allows an existing account, including the atta...
CVE-2026-81090	New	7.2	HIGH		0.003		The Gpx2Graphics WordPress plugin through 0.3 does not perform a CSRF check when handling file uploads, nor validate the type of the uploaded file, allowing attackers to make a logged-in administrator upload arbitrary files such as PHP via a CSRF attack, leading to Remote Code Execution.
CVE-2026-81429	New	7.1	HIGH		0.001		The Export & Import WPBakery Page Builder WordPress plugin through 1.0.2 does not perform any CSRF check on its template-import feature and does not sanitise the imported data before storing it and echoing it back, allowing attackers to make a logged-in administrator import a crafted template via a forged request that results in Stored Cross-Site Scripting executed in the ad...
CVE-2026-90555	New	7.1	HIGH		0.003	vllm:vllm	vLLM versions before 0.28.0 fail to validate audio sample rate headers in the transcription endpoint, allowing authenticated clients to bypass duration checks. Attackers can submit forged FLAC headers with inflated sample rates to trigger excessive memory allocation and crash the API server process affecting all tenants.
CVE-2026-90472	New	6.9	MEDI		0.003		msgpack-java through 0.9.12 contains a stack overflow vulnerability in MessageUnpacker.unpackValue() that recursively deserializes arrays and maps without nesting depth limits. Attackers can craft payloads with deeply nested arrays to exhaust the deserializing thread's stack and trigger StackOverflowError, causing per-request deserialization failures.
CVE-2026-90538	New	6.9	MEDI		0.002		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a missing authorization vulnerability in playlistsFromUser.json.php that allows unauthenticated attackers to read private playlists by requesting another user's identifier. Attackers can retrieve Favorite and Watch Later playlists belonging to other users due to improper cache keying that conflates ...
CVE-2026-90539	New	6.9	MEDI		0.002		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 contains a missing authentication vulnerability in the plugin/TopMenu/menultems.json.php endpoint that allows unauthenticated attackers to read inactive admin menu items by submitting a POST request with a menuId parameter. Attackers can retrieve hidden menu item URLs including embedded admin-tool secret que...
CVE-2026-90543	New	6.9	MEDI		0.003		WWBN AVideo at commit c3edcc274c389816d434acadac07ee78eaf330c1 and earlier, with the Live plugin enabled, contains a missing authentication vulnerability in plugin/Live/socketMessageLiveOwner.json.php. The script reads the `key` and `msg` parameters from \$_REQUEST, resolves the stream owner via LiveTransmition::keyExists, and verifies that the stream owner (not the caller) i...
CVE-2026-90547	New	6.9	MEDI		0.002		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 fails to validate user permissions in the Bookmark plugin getBookmarks.json.php endpoint, allowing unauthenticated attackers to read chapter names from password-protected videos. Attackers can query the endpoint with a video ID parameter to retrieve sensitive chapter metadata without authentication or passwo...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90548	New	6.9	MEDI		0.002		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 fails to validate user permissions in the ImageGallery list.json.php endpoint, allowing unauthenticated access to list gallery files. Attackers can retrieve filenames and URLs of password-protected image galleries by directly accessing the endpoint, then fetch the exposed files without authentication.
CVE-2026-90549	New	6.9	MEDI		0.002		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 fails to properly authorize access to the videosAndroid.json.php endpoint, allowing unauthenticated guests to list password-protected videos with sensitive owner information. Attackers can retrieve video metadata including owner email, lastLogin, filename, and hashId by sending an unauthenticated GET request...
CVE-2026-90550	New	6.9	MEDI		0.002		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 fails to check user authorization in the PlayerSkins mediaSession.json.php endpoint before returning video metadata. Unauthenticated attackers can request the endpoint with a video ID parameter to retrieve password-protected video titles and owner email addresses without authentication.
CVE-2026-90554	New	6.9	MEDI		0.001		vLLM versions >=0.10.2 and <0.28.0 do not apply any audio decode-size or duration limit when extracting audio from video input for NanoNemotronVL models. In nano_nemotron_vl.py, _extract_audio_from_videos calls load_audio_pyav(BytesIO(video_bytes)) without the max_duration_s or max_decode_bytes parameters, so neither VLLM_MAX_AUDIO_DECODE_DURATION_S nor VLLM_MAX_AUDIO_DECODE...
CVE-2026-90557	New	6.9	MEDI		0.001		Freeciv versions 3.1.0 through 3.2.5 contain an out-of-bounds read vulnerability in sg_load_player_unit() when processing savegame files with invalid unit activity indices. An attacker can craft a malicious savegame file with an out-of-range activity index that bypasses bounds checking and causes a crash or limited heap memory exposure when loaded.
CVE-2026-82847	New	6.8	MEDI		0.002		The Masteriyo LMS WordPress plugin before 3.4.1 does not sanitise and escape one of its course fields before outputting it back in the course editor, allowing users with the instructor role to perform Stored Cross-Site Scripting attacks against higher privileged users such as administrators.
CVE-2026-83532	New	6.8	MEDI		0.002		The Custom Menu Wizard Widget WordPress plugin through 3.3.1 does not sanitize and escape several shortcode attributes before rendering them into HTML, allowing users with contributor-level access and above to inject arbitrary web scripts that execute when the affected content is viewed.
CVE-2026-86790	New	6.8	MEDI		0.002		The WP Highlight Box WordPress plugin through 1.0 does not escape some shortcode attributes before outputting them in a page where the shortcode is embedded, which could allow users with the contributor role and above to perform Stored Cross-Site Scripting attacks.
CVE-2026-77161	New	6.5	MEDI		0.003		The Smart Marketing SMS and Newsletters Forms plugin for WordPress is vulnerable to generic SQL Injection via Parameter Name in all versions up to, and including, 5.1.24 due to insufficient escaping on the user supplied parameter and lack of sufficient preparation on the existing SQL query. This makes it possible for authenticated attackers, with subscriber-level access and ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84023	New	6.5	MEDI		0.001		The BEAR WordPress plugin before 1.2.2 does not verify a CSRF nonce or check user capabilities before updating taxonomy terms, allowing an attacker to modify arbitrary terms by tricking a logged-in privileged user into visiting a crafted page.
CVE-2026-85198	New	6.5	MEDI		0.003		The MPG – Multiple Page Generator, Bulk Landing Pages & Programmatic SEO plugin for WordPress is vulnerable to generic SQL Injection via URL Path in all versions up to, and including, 4.2.1 due to insufficient escaping on the user supplied parameter and lack of sufficient preparation on the existing SQL query. This makes it possible for authenticated attackers, with subscrib...
CVE-2026-87891	New	6.5	MEDI		0.002		The Rox Appointment Booking WordPress plugin before 1.2.0 does not perform any capability or authorization check when saving its holiday schedule, allowing unauthenticated attackers to overwrite the dates the booking system treats as unavailable, which can block legitimate bookings or open dates the site owner intended to keep closed.
CVE-2026-90533	New	6.5	MEDI		0.002	flowiseai:flowise	Flowise before 3.1.4 contains a broken access control vulnerability in GET /api/v1/organizationuser that allows any authenticated organization member to retrieve the organization owner's full user record including bcrypt password hash and temporary tokens. Attackers can query the endpoint with any user ID to obtain the owner's credential hash for offline cracking, enabling a...
CVE-2026-90534	New	6.5	MEDI		0.002	flowiseai:flowise	Flowise is a low-code platform for building LLM applications. In versions up to and including 3.1.3, the POST /api/v1/node-load-method/:name endpoint is mounted without any route-level permission check and invokes component loadMethods with an attacker-controlled nodeName, loadMethod, inputs, and credential value. The selected credential is resolved by raw Credential.id via ...
CVE-2026-10148	New	6.4	MEDI		0.003		The Booking for Appointments and Events Calendar plugin for WordPress is vulnerable to Stored Cross-Site Scripting via multiple Elementor widgets in versions up to and including 2.4.9. This is due to insufficient input sanitization and output escaping on the 'load_manually' parameter in the render() methods of classes. This makes it possible for authenticated attackers, with...
CVE-2026-90467	New	6.3	MEDI		0.002		aioSMTPlib before 5.1.3 fails to properly validate email addresses supplied by callers, allowing attackers to inject ESMTP parameters into MAIL FROM and RCPT TO command lines. Attackers can craft malicious addresses containing spaces and angle brackets to append parameters like AUTH, NOTIFY, or ORCPT to envelope commands, forging authenticated identities or forcing delivery ...
CVE-2026-89172	New	5.6	MEDI		0.002		Improper protection of physical side channels vulnerability in Microchip AN1044, Microchip AN953, and Microchip SW300052. This issue affects AN1044: through A; AN953: through A; SW300052: through 2.6.
CVE-2026-77753	New	5.5	MEDI		0.002		The Temporary Login Without Password WordPress plugin before 1.9.9 does not prevent a temporary user from creating an Application Password, and does not revoke one when the temporary access expires or is disabled, allowing the recipient of a temporary login to retain working access to the site over REST and XML-RPC after the administrator believes it has been withdrawn. The ...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90485	New	5.4	MEDI		0.002		A flaw has been found in IOBit Uninstaller 15.5.0.11. Affected by this issue is the function sub_11838 of the file IURegistryFilter.sys of the component IOCTL Dispatch Handler. This manipulation causes null pointer dereference. The attack requires local access. The exploit has been published and may be used. Identical IURegistryFilter.sys ships across multiple IObit families...
CVE-2026-11355	New	5.3	MEDI		0.002		The DT LMS – elearning, WordPress LMS plugin for WordPress is vulnerable to unauthorized modification of data due to a missing capability check on multiple AJAX handlers (including dtlms_save_poc_settings, dtlms_save_skin_settings, and dtlms_save_options_settings) in versions up to, and including, 1.1. These handlers are registered on the wp_ajax_nopriv_* hook and contain no...
CVE-2026-17585	New	5.3	MEDI		0.003		The Royal Addons for Elementor – Addons and Templates Kit for Elementor plugin for WordPress is vulnerable to Sensitive Information Exposure in all versions up to, and including, 1.7.1066 via the 'wpr_keyword' parameter. This makes it possible for unauthenticated attackers to extract arbitrary postmeta values from all published posts via character-by-character substring match...
CVE-2026-77689	New	5.3	MEDI		0.002		The Booking for Appointments and Events Calendar WordPress plugin before 9.8.1 does not verify that a payment was actually taken before recording a booking as paid, trusting the payment gateway named in a public, unauthenticated booking request even when the site has never configured that gateway. This lets an unauthenticated attacker obtain confirmed, fully paid appointments...
CVE-2026-78152	New	5.3	MEDI		0.002		The SureRank SEO WordPress plugin before 1.10.1 does not exclude users' registered account email addresses from the structured data it outputs on public pages by default, allowing unauthenticated visitors to obtain the email address of any user who has published content.
CVE-2026-87892	New	5.3	MEDI		0.002		The Rox Appointment Booking WordPress plugin before 1.2.0 does not verify the order total or the selected payment method against its own server-side pricing when creating a booking, allowing unauthenticated attackers to create confirmed bookings at an arbitrary price and to bypass the site's configured payment-method restrictions.
CVE-2026-87894	New	5.3	MEDI		0.002		The Rox Appointment Booking WordPress plugin before 1.2.3 does not perform any authorization check on the endpoint that returns a booking's confirmation details, and each booking is addressed by a sequential numeric identifier, allowing unauthenticated attackers to read any customer's name, email, phone, booking details and payment status by enumerating that identifier.
CVE-2026-87916	New	5.3	MEDI		0.002		The WPBot WordPress plugin before 8.6.0 does not perform any capability or nonce check on the AJAX action that lists stored chat sessions, allowing unauthenticated attackers to retrieve the name, email address and phone number of every chat visitor by requesting a wide date range.
CVE-2026-87918	New	5.3	MEDI		0.002		The WPBot WordPress plugin before 8.5.7 does not perform any authorization or nonce check on several AJAX actions that relay prompts to its configured AI providers, allowing unauthenticated attackers to make those third-party API calls, and consume the associated cost, using the site's own configured API keys.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-89267	New	5.3	MEDI		0.002		starlette-admin versions 0.16.1 through 0.17.1 fail to enforce the searchable_fields allowlist when configured as an empty list, allowing authenticated users to filter on non-searchable fields. Attackers can submit structured filter queries via the list API's where parameter to perform equality and comparison operations on excluded columns.
CVE-2026-90473	New	5.3	MEDI		0.002		msgpack-java through 0.9.12 contains an integer overflow vulnerability in MessageUnpacker.skipValue() when processing MAP32 containers with large element counts. Attackers can supply a MAP32 element count at or above 0x40000000 that wraps when doubled, causing the parser cursor to desynchronize and attacker-controlled data to be returned in place of later fields.
CVE-2026-90486	New	5.3	MEDI		0.002		A vulnerability has been found in openstatusHQ openstatus up to f04c827112f30a11d571ebdad3892826034d6265. Affected by this vulnerability is an unknown functionality of the file apps/status-page/src/lib/proxy/resolve-custom-domain-rewrite.ts. The manipulation leads to server-side request forgery. The attack may be initiated remotely. This product uses a rolling release model ...
CVE-2026-90536	New	5.3	MEDI		0.002		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 fails to authorize access to the adsInfo API endpoint, allowing unauthenticated attackers to retrieve password-protected video owner identifiers. Attackers can call the adsInfo API with a videos_id parameter to obtain the owner's user ID and personalized ad creative URLs without authentication or permission ...
CVE-2026-90540	New	5.3	MEDI		0.002		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 fails to validate watch permissions in the playListAddVideo.json.php endpoint when adding videos to playlists. Authenticated attackers can add password-protected videos they cannot watch to playlists they own by submitting the video ID and playlist ID parameters.
CVE-2026-90541	New	5.3	MEDI		0.002		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 fails to require authentication in the plugin/TopMenu/menus.json.php endpoint, allowing unauthenticated attackers to retrieve all menu data. Attackers can send GET requests to the endpoint to read inactive and admin-only menu names that are not displayed in the public navbar.
CVE-2026-90542	New	5.3	MEDI		0.001		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 fails to validate that logged-in users can access live schedules before creating reminders via remindMe.json.php. Authenticated attackers can create scheduler reminders for private live schedules they cannot view and learn the private schedule title from the generated email job.
CVE-2026-90544	New	5.3	MEDI		0.002		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 fails to validate video access permissions in the videoAddViewCount.json.php endpoint before updating view statistics. Authenticated attackers can increment view counts and watch-time on videos they cannot access by submitting requests with arbitrary video IDs.
CVE-2026-90545	New	5.3	MEDI		0.002		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 fails to validate video access permissions in the commentAddNew.json.php endpoint, allowing authenticated users to post comments on password-protected and group-restricted videos. Attackers can submit POST requests with a valid session to add comments to videos they cannot watch, bypassing password and group...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-90551	New	5.3	MEDI		0.002		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 fails to validate playlist ownership in the video_from_program API endpoint, allowing unauthenticated access to private playlist contents. Attackers can query the API without authentication to enumerate private playlist names, owner information, and video titles including password-protected content.
CVE-2026-90552	New	5.3	MEDI		0.002		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 fails to validate playlist ownership in the Playlists_schedules/list.json.php and Live/calendar.json.php endpoints, allowing authenticated and unauthenticated users to read private playlist schedule metadata. Attackers with canStream privileges or no authentication can retrieve schedule names, descriptions, ...
CVE-2026-89268	New	5.1	MEDI		0.002		QloApps through 1.7.0 renders back-office list filter POST parameters into HTML input value attributes without escaping them in the list helper template. Attackers can induce authenticated users to submit crafted POST requests with malicious payloads to list controllers, executing arbitrary JavaScript in the victim's session to read administrative data and perform actions.
CVE-2026-87919	New	4.9	MEDI		0.002		The Product XML Feed Manager for WooCommerce WordPress plugin before 3.1.1 does not restrict which object method its product shortcode may call, nor check the user's capability over the targeted product, allowing users with contributor-level access to delete arbitrary WooCommerce products by previewing a post that contains the shortcode.
CVE-2026-84024	New	4.3	MEDI		0.001		The BEAR WordPress plugin before 1.2.2 does not verify a CSRF nonce before saving its meta field configuration, allowing an attacker to overwrite that configuration by tricking a logged-in administrator into visiting a crafted page.
CVE-2026-87797	New	4.3	MEDI		0.002		The Sprout Invoices WordPress plugin before 20.8.16 does not perform a capability or ownership check before allowing a private note to be overwritten through one of its AJAX actions, allowing any authenticated user such as a subscriber to overwrite private notes on records belonging to other users.
CVE-2026-90546	New	4.3	MEDI		0.002		WWBN AVideo through commit c3edcc274c389816d434acadac07ee78eaf330c1 fails to validate video access permissions in the like.json.php endpoint, allowing logged-in users to record likes on password-protected and group-restricted videos. Attackers can submit like requests for videos they cannot watch to increment like counters and bypass access controls.
CVE-2026-79300	New	3.5	LOW		0.002		SEP sesam before 5.2.0.24 mishandles User Authorization with MFA. If AD authentication is configured and MFA is enforced, an attacker can create a second OTP access capability. SEP sesam and Active Directory handle username capitalization differently, which may allow multiple SEP sesam user accounts to be created for the same Active Directory (AD) account. Active Directory t...
CVE-2026-82851	New	2.7	LOW		0.002		The Masteriyo LMS WordPress plugin before 3.4.1 does not verify ownership of, or restrict the type of, the records a user requests for download, allowing users with the instructor role to retrieve the full content and metadata of arbitrary posts, including other instructors' private and draft courses.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84025	New	2.2	LOW		0.002		The BEAR WordPress plugin before 1.2.2 does not perform ownership checks on several handlers that return product data by a user-supplied identifier, allowing users who are restricted to their own products to read other owners' product information, including protected downloadable file URLs and private product metadata.
CVE-2026-90487	New	2.1	LOW		0.002		A vulnerability was found in Xuxueli xxl-job up to 3.4.2. Affected by this issue is some unknown functionality of the file xxl-job-admin/src/main/java/com/xxl/job/admin/business/controller/JobGroupController.java. The manipulation results in improper privilege management. The attack may be launched remotely. The exploit has been made public and could be used. The vendor was ...
MAL-2026-16142	New					PyPI:python-fork	--- _-= Per source details. Do not edit below this line._= _ ## Source: kam193 (0bff88696e931354b786185cde4b21e28c27407203c5733ac31b52b7186c1e78) Importing the module starts a fork bomb, what can lead to destabilizing the system. --- Category: MALICIOUS - The campaign has clearly malicious intent, like infostealers. Campaign: 2026-09-python-fork Reasons (based on the...
MAL-2026-16165	New					npm:@biz44/id10-client	This package is part of a malicious npm campaign published by the `biz44` account. Importing the package automatically launches a detached JavaScript loader that retrieves and executes additional code from npoint.io. The retrieved payload communicates with an attacker-controlled server and implements clipboard collection, keyboard and mouse event collection, filesystem scann...
MAL-2026-16166	New					npm:@biz44/id12-client	This package is part of a malicious npm campaign published by the `biz44` account. Importing the package automatically launches a detached JavaScript loader that retrieves and executes additional code from npoint.io. The retrieved payload communicates with an attacker-controlled server and implements clipboard collection, keyboard and mouse event collection, filesystem scann...
MAL-2026-16167	New					npm:@biz44/id44-client	This package is part of a malicious npm campaign published by the `biz44` account. Importing the package automatically launches a detached JavaScript loader that retrieves and executes additional code from npoint.io. The retrieved payload communicates with an attacker-controlled server and implements clipboard collection, keyboard and mouse event collection, filesystem scann...
MAL-2026-16168	New					npm:@biz44/id79-client	This package is part of a malicious npm campaign published by the `biz44` account. Importing the package automatically launches a detached JavaScript loader that retrieves and executes additional code from npoint.io. The retrieved payload communicates with an attacker-controlled server and implements clipboard collection, keyboard and mouse event collection, filesystem scann...
MAL-2026-16169	New					npm:@biz44/id95-client	This package is part of a malicious npm campaign published by the `biz44` account. Importing the package automatically launches a detached JavaScript loader that retrieves and executes additional code from npoint.io. The retrieved payload communicates with an attacker-controlled server and implements clipboard collection, keyboard and mouse event collection, filesystem scann...
MAL-2026-16170	New					npm:@biz44/id99-client	This package is part of a malicious npm campaign published by the `biz44` account. Importing the package automatically launches a detached JavaScript loader that retrieves and executes additional code from npoint.io. The retrieved payload communicates with an attacker-controlled server and implements clipboard collection, keyboard and mouse event collection, filesystem scann...

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
MAL-2026-16173	New					npm:id79-client	This package is part of a malicious npm campaign published by the `biz44` account. Importing the package automatically launches a detached JavaScript loader that retrieves and executes additional code from npoint.io. The retrieved payload communicates with an attacker-controlled server and implements clipboard collection, keyboard and mouse event collection, filesystem scann...

Significant updates today - original Published Date retained

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-84869	Updated - CVSS added	9.9	CRIT	Yes	0.007	connectwise:screenconnect	A condition in the ScreenConnect client may allow files to be transferred and executed through an active remote session without authorization or Host confirmation in certain circumstances. ScreenConnect servers are not impacted.

Added to CISA KEV today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-58704	Added to KEV	8.8	HIGH	Yes	0.001	google:pixel	Google Pixel devices contain an improper authorization vulnerability in the cellular modem. A logic error may allow an attacker to bypass permission checks and escalate privileges.
CVE-2026-76460	Added to KEV			Yes		cisco:identity services engine	Cisco Identity Services Engine (ISE) and Cisco ISE Passive Identity Connector (ISE-PIC) contain an incorrect use of privileged APIs vulnerability that could allow an unauthenticated, remote attacker to gain unauthorized access to the affected device by bypassing the web-based management interface.
CVE-2026-76461	Added to KEV			Yes	0.02	cisco:secure email gateway	Cisco AsyncOS software for Cisco Secure Email Gateway (SEG) contains a SQL injection vulnerability that could allow an unauthenticated, remote attacker to execute arbitrary commands with root privileges on the underlying operating system.
CVE-2026-87886	Added to KEV			Yes		acronis:backup	Acronis Backup plugin for cPanel & WHM and extension for Plesk contains an incorrect default permissions vulnerability that could allow for privilege escalation.

P1 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-85706	New	10.0	CRIT	Yes	0.12	gitlab:gitlab	GitLab has remediated an issue in GitLab CE/EE affecting all versions from 18.7 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that, under certain conditions, an unauthenticated user could have read arbitrary files from the GitLab server due to improper path confinement and missing authentication enforcement in the repository commits API.

P2 new today

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-82845	New	9.9	CRIT		0.004		The Masteriyo LMS WordPress plugin before 3.4.1 does not prevent user-supplied values held as metadata from being deserialized when they are read back, allowing users with a minimal account to inject arbitrary PHP objects and, by way of a class shipped in a library bundled with the Masteriyo LMS WordPress plugin before 3.4.1, write and execute arbitrary code on the server....
CVE-2026-87719	New	9.9	CRIT		0.006		GitLab has remediated an issue in GitLab EE affecting all versions from 18.3 before 19.1.8, 19.2 before 19.2.6, and 19.3 before 19.3.2 that under certain conditions could allow an authenticated user with Duo Chat access to obtain Advanced Search instance configurations and sensitive credentials using a specially crafted GraphQL subscription argument to bypass serialization a...
CVE-2026-75800	New	9.8	CRIT		0.004		The Frontegg SAML SSO WordPress plugin through 1.0.1 does not verify the signature or issuer of SAML authentication responses before establishing a session, allowing unauthenticated attackers to log in as any user, including administrators, as well as to create arbitrary accounts.
CVE-2026-78006	New	9.8	CRIT		0.008		The The Events Calendar plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 6.17.4 via the <code>is_safe_widget_instance</code> function. This is due to insufficient protection in <code>is_safe_widget_instance</code> , which can be bypassed because PHP fires magic methods during its pre-parse, combined with <code>enable_rendering_widget_copied()</code> forging a valid ...
CVE-2026-78159	New	9.8	CRIT		0.008		The The Events Calendar plugin for WordPress is vulnerable to Remote Code Execution in all versions up to, and including, 6.17.3 via the <code>parse_array</code> function. This is due to insufficient validation of the widget 'classes' map, allowing a plain-array payload to bypass the <code>is_safe_widget_instance()</code> object check and reach the callable-invocation sink in <code>Element_Classes::parse_a...</code>
CVE-2026-81402	New	9.8	CRIT		0.004		The DS Ad Rotator WordPress plugin through 0.8 does not perform any capability check, nonce verification, or file-type validation on its image upload handler, allowing unauthenticated attackers to upload arbitrary files, including PHP, to a web-accessible directory, which can lead to remote code execution.
CVE-2026-84171	New	9.8	CRIT		0.004		The WP images upload on piclect WordPress plugin through 1.0 does not validate the name or type of uploaded files before writing them to a publicly accessible directory, allowing unauthenticated attackers to upload arbitrary files and execute arbitrary code on the server.
CVE-2026-85681	New	9.8	CRIT		0.003		The WP Component WordPress plugin through 2.2.4 does not have any capability or nonce checks on one of the actions it makes available to unauthenticated users, and it takes both the option name and the option value from the request, allowing unauthenticated attackers to overwrite any of the site's options. On a single site installation this leads to a full takeover, as regis...
CVE-2026-77005	New	9.6	CRIT		0.003		The CODE MONKEYS PROPOSALS WordPress plugin through 1.0.1 does not validate a user-supplied file path before deleting a file, and does not check the capability of the user making the request, allowing any authenticated user, such as a subscriber, to delete arbitrary files on the server, which can lead to a site takeover.

ID	Reason	CVSS	Sev	KEV	EPSS	Vendor / Product / Package	Description
CVE-2026-77006	New	9.6	CRIT		0.002		The WebTotem Backups WordPress plugin through 1.0.1 does not validate a user-supplied file path, does not check the capability of the user making the request, and discards the result of its own CSRF check, allowing any authenticated user, such as a subscriber, to delete arbitrary files on the server, which can lead to a site takeover.
CVE-2026-90558	New	9.3	CRIT		0.005		sngrep through 1.8.4 contains stack buffer overflow vulnerabilities in SIP attribute formatting routines when header values exceed the 255-byte buffer limit. Attackers can craft malicious SIP packets with oversized Call-ID, X-Call-ID, or other header fields to overflow stack buffers and cause crashes or execute arbitrary code during packet parsing and rendering.
CVE-2026-90647	New	9.1	CRIT		0.001		ASE/Kalkitech ASE2000 V2 Communication Test Set 2.35 through 2.37 on Windows contains an improper certificate validation vulnerability in the IEC 60870-5-104 TLS client (Task Mode). This allows a network-positioned attacker to bypass certificate validation via a certificate with multiple simultaneous faults, enabling a Man-in-the-Middle attack on protected communications.

Historical reports are not rewritten when an older CVE changes. A CVE published on an earlier date remains in that earlier daily report; a meaningful change is shown separately in the update section for the date on which the change was detected.